MODULE 25 · DOMAIN 4 - SECURITY AND COMPLIANCE

Multi-Account Governance

Organizations, SCPs, RCPs, declarative policies, delegated administration and IAM Identity Center.

DOMAIN 4 of 5 EXAM WEIGHT 16% MODULE 25 of 35

admin@sthithapragna.com

Four policy types, four different objects governed: **principals**, **resources**, **configuration**, and **metadata**. Match the question to the object.

The structure

- One **management account**, many **member accounts**, arranged in a tree of **organisational units** beneath the **root**.
- Policies attach to the root, an OU, or an individual account, and are **inherited downward**.
- **All features** must be enabled to use SCPs and RCPs. Consolidated billing only is the restricted mode.
- Keep the **management account empty of workloads**. Several controls do not apply to it, which makes it the wrong place for anything.

> ON THE EXAM
>
> The management account is exempt from SCPs and RCPs. Running production there means running it outside your own guardrails.

The organization policy types

POLICY TYPE	GOVERNS
Service control policy	What principals in member accounts may do
Resource control policy	What may be done to resources in member accounts
Declarative policy	The configuration of a service, maintained permanently
Tag policy	Allowed tag keys, values and casing
Backup policy	Backup plans pushed down so accounts cannot opt out
AI services opt-out	Whether AI services may store and use your content

ON THE EXAM

The first three are the ones that decide questions. Only the first two are access controls; declarative policies are configuration, not permission.

How SCPs actually behave

- An SCP **never grants**. It sets the maximum available permissions for principals in the accounts it covers.
- **Inheritance is an intersection.** A permission must be allowed at every level from the root down to the account.
- **FullAWSAccess** is attached at the root by default. Detach it and, unless you allow explicitly at every level, everything stops.
- It applies to **every principal in the account, including the root user**. That is what makes it a real boundary.

> ON THE EXAM
>
> SCPs limit what an account can do. They never give an account anything, so an account with only SCPs and no IAM grants has no access at all.

Deny list or allow list?

DENY LIST

The common approach

- Keep FullAWSAccess, add Deny statements
- Deny Regions, deny specific services, deny disabling CloudTrail
- Easy to add a rule; nothing breaks unexpectedly
- New AWS services are permitted by default

ALLOW LIST

Strict, and high maintenance

- Detach FullAWSAccess, allow only named services
- New services are blocked until explicitly added
- Very strong control in regulated environments
- Every new service adoption becomes a policy change

THE TIEBREAKER

Deny lists are what most organisations run. Allow lists are correct where the requirement is that nothing unapproved can ever be used.

Two exceptions worth memorising

- **SCPs do not apply to the management account**, whatever you attach and wherever you attach it.
- **SCPs do not apply to service-linked roles**, as module 24 covered. That exception exists so AWS services keep working.
- They **do** apply to infrastructure roles such as those used by ECS Managed Instances and EKS Auto Mode, which module 21 showed can break things.
- **RCPs also do not affect resources in the management account**, and do not affect resources owned outside the organisation.

> ON THE EXAM
>
> Two similar-sounding roles, opposite behaviour. Service-linked roles are exempt; infrastructure roles are not. That distinction has appeared twice in this course.

Resource control policies

- Launched **November 2024**. Where an SCP caps what your principals may do, an RCP caps **what may be done to your resources**.
- The headline use is a **data perimeter**: no principal outside my organisation may access my S3 buckets, regardless of any bucket policy.
- Started with **S3, STS, KMS, SQS and Secrets Manager**. By 2026 it covers **more than two dozen services**, including ECR, DynamoDB, Cognito and CloudWatch Logs.
- **RCPFullAWSAccess** is attached by default, exactly as FullAWSAccess is for SCPs.

> ON THE EXAM
>
> An SCP cannot stop a bucket policy someone wrote in a member account from granting access outward. An RCP can, centrally, for every bucket at once.

SCP or RCP?

SCP WHEN

The subject is your people

- Restrict which Regions may be used
- Prevent disabling CloudTrail or Config
- Block specific services entirely
- Applies to principals in member accounts

RCP WHEN

The subject is your data

- No access from outside the organisation
- Require TLS on every bucket, centrally
- Override a permissive resource policy you do not control
- Applies to resources in member accounts

THE TIEBREAKER

Ask who is acting. If the risk is your engineers doing something, that is an SCP. If the risk is somebody else reaching your data, that is an RCP.

Declarative policies

- Generally available **December 2024**. They enforce a **desired configuration** for a service, rather than a permission.
- **Set once and forget:** the configuration is maintained **even when the service adds new APIs or features**, and for accounts that join later.
- Today they cover **EC2, EBS and VPC**: VPC Block Public Access, image and snapshot block public access, **Allowed AMIs**, **IMDSv2 defaults**, serial console access.
- The **account status report** shows the current value of every attribute across the organisation, so you can assess readiness before enforcing.

> ON THE EXAM
>
> This is where module 21's Allowed AMIs and module 7's IMDSv2 requirement get enforced organisation-wide, rather than account by account.

Declarative policy or SCP?

SCP WHEN

Block an action

- Deny an API call outright
- Any service, any action
- Says what may not be done
- New APIs may not be covered by your wording

DECLARATIVE POLICY WHEN

Enforce a setting

- Declare the value a setting must have
- EC2, EBS and VPC today
- Says what the configuration must be
- Survives new APIs and features automatically

THE TIEBREAKER

An SCP denies actions you thought of. A declarative policy states an outcome, so a new API that would change that setting is covered without editing anything.

Delegated administration

- A **member account** is nominated to administer a service for the whole organisation, so the management account is not used daily.
- Supported widely: **GuardDuty, Security Hub, Config, IAM Access Analyzer, Backup, CloudFormation StackSets, Firewall Manager, Inspector, Macie**.
- This is **per service**. Delegating GuardDuty does not delegate Config, and each is registered separately.
- **Some actions still require the management account**, including creating accounts, and attaching most organisation policies.

> ON THE EXAM
>
> The goal is that nobody needs management account credentials for routine work. That is a security control, not an organisational preference.

IAM Identity Center

- One place for workforce sign-in across every account. Users get an **access portal** listing the accounts and roles they may use.
- **Identity sources**: the built-in Identity Center directory, Active Directory, or an external provider via SAML with SCIM for provisioning.
- A **permission set** is a template. When assigned, Identity Center **creates and maintains an IAM role** in that account.
- An assignment is three things together: **a user or group, a permission set, and an account**.

> ON THE EXAM
>
> Permission sets become IAM roles. Everything from module 24 still applies, including SCPs, boundaries and the evaluation order.

Identity Center or IAM users?

IDENTITY CENTER

People

- Central sign-in, one identity across all accounts
- Temporary credentials, no long-lived keys
- Joiners and leavers handled in the identity provider
- Session duration 1 to 12 hours

IAM USERS

Rarely the answer now

- Long-lived access keys that leak
- Per account, so one person needs many
- Deprovisioning means finding every account
- Occasionally unavoidable for legacy tooling

THE TIEBREAKER

"Users must be deprovisioned everywhere when they leave" is Identity Center. With IAM users, leaving is a search-and-delete exercise across every account.

Identity Center details worth knowing

- **Session duration** is configurable from 1 to 12 hours per permission set. Shorter for privileged access.
- **Attribute-based access control** uses identity attributes as session tags, so one permission set serves many teams.
- Permission sets can include **AWS managed policies, customer managed policies and a permissions boundary**.
- Deleting an assignment **removes the IAM role** from that account. The role is managed, not yours to edit.

> ON THE EXAM
>
> Editing the generated IAM role by hand is a mistake. Identity Center reconciles it, and your change disappears at the next provisioning.

Consolidated billing

- One bill for the organisation. **Usage aggregates**, so volume discount tiers are reached faster.
- **Reserved Instances and Savings Plans are shared** across accounts by default, so unused commitment benefits somebody else.
- Sharing can be **turned off per account**, which is how you stop one team consuming another team's commitment.
- **Cost allocation tags must be activated in the management account**, and they are not retroactive. Module 23 covered this.

> ON THE EXAM
>
> Discount sharing is on by default. If a team has bought capacity for a specific workload, someone must decide whether it should be shared.

> A security team attaches an SCP to the organisation root denying ec2:RunInstances outside three approved Regions. Testing confirms it works in member accounts. A week later they find an engineer has launched instances in an unapproved Region.
>
> The instances are in the management account.

What explains this?

A The SCP needs to be attached to each OU as well as the root

B SCPs do not apply to the management account

C The engineer used the root user, which SCPs do not affect

D The SCP takes up to 24 hours to propagate

◆ PAUSE AND DECIDE

What explains this?

A Attach to each OU

Policies attached at the root are inherited by every OU and account beneath it. Re-attaching changes nothing.

B SCPs do not apply to the management account

Documented behaviour, and the reason AWS advises keeping workloads out of the management account entirely.

C Root user is exempt

Precisely backwards. SCPs apply to every principal in a member account including the root user, which is what makes them a real boundary.

D 24-hour propagation

Invented. The scenario also states the policy was confirmed working in member accounts, so it had already taken effect.

THE SIGNAL

The last line of the setup is the whole answer. Option C is the same fact inverted, which makes it the most attractive wrong answer.

> An audit finds several S3 buckets across member accounts with bucket policies granting access to external AWS accounts. The security team cannot review every bucket policy, and application teams own their own buckets.
>
> They need a central control ensuring no principal outside the organisation can access any S3 bucket, regardless of what a bucket policy says.

What should the team implement?

A An SCP denying s3:PutBucketPolicy in all member accounts

B A resource control policy denying S3 access to principals outside the organisation

C S3 Block Public Access enabled at the account level everywhere

D An IAM Access Analyzer external access analyzer at organisation level

◆ PAUSE AND DECIDE

What should the team implement?

A Deny PutBucketPolicy

Stops new bucket policies being written and does nothing about the ones that already exist. It also blocks legitimate use entirely.

B RCP denying external principals

Caps what may be done to the resources themselves, overriding any bucket policy, for every bucket at once. Exactly the data perimeter use case.

C Account-level Block Public Access

Blocks public access. Access granted to a named external AWS account is not public, so it passes straight through.

D External access analyzer

Detective. It reports the sharing the audit already found, and prevents nothing.

THE SIGNAL

Option C is the sharp one: cross-account is not the same as public. Block Public Access would leave every one of these grants in place.

> An organisation must ensure that every EC2 instance launched anywhere, in any account, now or in future, requires IMDSv2. They previously wrote an SCP denying RunInstances without the correct metadata options. New launch paths and new APIs kept bypassing the wording.
>
> They want the setting itself enforced rather than specific calls denied.

What should they use?

A. A declarative policy setting instance metadata defaults across the organisation

B. A more comprehensive SCP covering every launch API

C. An AWS Config rule with automatic remediation

D. A CloudFormation Hook rejecting non-compliant templates

◆ PAUSE AND DECIDE

What should they use?

A Declarative policy for metadata defaults

Declares the setting's value rather than denying calls, and is maintained as the service adds new APIs and as accounts join.

B A better SCP

The approach that already failed, written more carefully. It still enumerates calls, so a future API needs a policy update.

C Config rule with remediation

Detective then corrective. Instances exist non-compliant before being fixed, which the requirement does not accept.

D CloudFormation Hook

Preventive, and only for resources created through CloudFormation. Console and CLI launches bypass it entirely.

THE SIGNAL

The scenario states the failure mode of enumeration: new APIs slip past. That is precisely the gap declarative policies were built to close.

> A company with 60 accounts wants its security team to manage GuardDuty and Security Hub findings organisation-wide. Nobody should use management account credentials for daily work.
>
> The security team also needs to create new accounts occasionally.

What should the company configure?

A Register the security account as delegated administrator for GuardDuty and for Security Hub separately, and keep account creation in the management account

B Register the security account as delegated administrator once, which covers all services

C Give the security team an IAM role in the management account with administrator access

D Create a separate organisation for the security team

◆ PAUSE AND DECIDE

What should the company configure?

A Delegate per service; keep account creation central

Delegated administration is registered per service, and account creation genuinely still requires the management account.

B Delegate once for everything

The plausible assumption, and wrong. Each service is registered independently; delegating GuardDuty says nothing about Security Hub.

C Admin role in the management account

Exactly what the requirement forbids: daily work performed with management account credentials.

D A separate organisation

Splits the estate in two, so organisation-wide findings become impossible. It defeats the purpose entirely.

THE SIGNAL

Two facts, both easy to get wrong: delegation is per service, and creating accounts is one of the things that stays in the management account.

> Engineers currently have IAM users in each of 30 accounts. When someone leaves, an administrator must find and delete their user in every account, and this has been missed twice. Access keys are shared in team documents.
>
> The company already runs a corporate identity provider supporting SAML.

What should the company implement?

A. IAM Identity Center with the corporate IdP as identity source, and permission sets assigned to groups

B. A single IAM user per engineer in the management account, assuming roles into the others

C. An SCP denying iam:CreateUser in all member accounts

D. Rotate all access keys automatically every 30 days

◆ PAUSE AND DECIDE

What should the company implement?

A Identity Center with the corporate IdP

Removing someone from a group in the IdP removes their access everywhere at once, and there are no long-lived keys to share.

B One user in the management account

Better than 30 users, and it still relies on long-lived keys and puts human identities in the management account.

C Deny CreateUser

Stops new users appearing and does nothing about the 30 accounts' worth that already exist, or about the shared keys.

D Rotate keys every 30 days

A key shared in a document is compromised the moment it is shared. Rotating it later does not un-share the previous one.

THE SIGNAL

Two failures are described: deprovisioning missed, and keys shared. Central identity with temporary credentials fixes both; nothing else fixes either properly.

The five things to carry forward

- **SCPs cap principals; RCPs cap resources.** Ask who is acting and what is being reached.
- **SCPs skip the management account and service-linked roles.** They do not skip infrastructure roles.
- **Declarative policies enforce a setting, not an action**, and survive new APIs and new accounts.
- **Delegated administration is per service.** Account creation stays in the management account.
- **Identity Center permission sets become real IAM roles**, so module 24's evaluation order still applies to them.

ON THE EXAM

Next: encryption and secrets - KMS keys, key policies, grants, ACM and Secrets Manager.